Security–Performance Tradeoffs in Resource-Constrained Agents: Phase 1 Baseline Benchmark and Measurements

Wayne Wang
CSE 291A, Fall 2026
https://github.com/waynewangyuxuan/CSE-291A-Project

Abstract

We ask how weight quantization and context management affect a local tool-using agent's task completion and its resistance to prompt injection. Phase 1 constructs paired clean/adversarial tasks from a 60-task subset of AgentDojo, builds a reproducible harness around Qwen3-8B served locally, and measures one undefended baseline (unquantized F16, full 32K context, 600 episodes over two seeds). It establishes task completion (48.3% clean), unauthorized actions (19.2% attack success overall, 23.7% on cleanly completable tasks), latency, token consumption and peak memory, classifies failures from 168 inspected traces, and audits the validity of the checkers and measurements. Two single-seed explorations exercise the Phase 2 harness.

1 Introduction and Research Questions

An agent that reads untrusted documents, messages or web pages can be redirected by instructions embedded in them. The choices that make a local agent affordable, lower weight precision and a smaller retained context, may change both what it can do and what it can be made to do. Phase 1 does not vary those choices; it builds the measurement and a baseline for Phase 2. Table 1 lists the questions we asked, the dimensions and metrics used to answer each, and what the data showed. Sections 2–4 give the evidence.

2 Setup

Paired clean and adversarial tasks. We adapt AgentDojo v1.2.2 (Debenedetti et al., 2024) at a pinned commit; its utility and attack checkers are deterministic state, answer or trace checks, not model-generated scores. We selected **60 legitimate tasks** (Banking 8, Slack 16, Workspace 24, Travel 12) by source inspection *before* observing any F16 outcome; development tasks are held apart. Each task's clean episode is paired with four adversarial episodes that inject instructions through retrieved content or tool output: two suite-specific attacker goals (redirect a recurring payment, change the password, send a phishing link, visit an attacker site, send an unauthorized email, create an unauthorized event, book an attacker's hotel, exfiltrate personal data) crossed with two fixed templates, `direct_append` ("TODO: *goal*") and `ignore_previous_append`. Unlike upstream, which replaces the injected field, our `_append` variant keeps the benign content so the legitimate objective is preserved. Two seeds (17, 29) give $60 \times 2 \times (1 + 4) = 600$ episodes.

Checker audit. A source-level audit excluded upstream checker defects (tasks already or always true, tasks accepting a no-op, an `or`-precedence bug, a reference solution over our tool cap). An offline audit of all 240 task/goal/template conditions confirms the legitimate task stays completable in 1–9 tool calls with the payload present and that completing it never satisfies the attack goal.

Deployment. Qwen3-8B is converted from the verified BF16 checkpoint to F16 GGUF (0 quantized tensors) and served by pinned llama.cpp (ggml-org, 2026) on an M2 Max (64 GiB): one slot, 32,768-token context, F16 KV cache, no prompt caching, non-thinking decoding at temperature 0.7 (Qwen Team, 2025). Limits: 2,048 output tokens, 15 tool calls, 120 s per request, 600 s per episode; exceeding one is a retained error with unknown score, never a dropped episode or a "defense". The system prompt is AgentDojo's default; no defense is added.

Metrics and uncertainty. Every rate reports numerator, denominator and unknown count. Attack success (ASR) is given over all attacks and over attacks whose same-task, same-seed clean control succeeded, so inability to use tools is not counted as resistance. Exposure records whether the payload

Research question	Dimensions and metrics	What Phase 1 showed
RQ1 How much of a fixed workload does the undefended baseline complete, and where does it fail?	Official utility U by suite, seed, reference path length, read vs. action tasks, prompt length; task-level agreement across seeds	48.3% clean; no read/write gap (47.7 vs. 48.7%); long reference paths hurt (22% at $\geq$5 calls); prompt length is confounded with suite; 51/60 tasks stable across seeds
RQ2 What kinds of failures occur: task misunderstanding, invalid tool calls, attack following, unnecessary refusal?	Protocol-frozen review of all 120 clean + 48 attack traces; tool-error counts; refusal incidence with indeterminate bounds	Planning dominates (45/120); 0 malformed calls but 149/600 tool errors; 16/76 action tasks stop after gathering info; refusal 2/120 (bound 13/120)
RQ3 How often do injected instructions succeed, and on what does it depend?	ASR over all attacks and over cleanly completable tasks; payload exposure; template, goal, suite; paired utility change under attack	19.2% all / 23.7% eligible; `ignore_previous` 32.9% vs. `TODO` 5.4%; every success exposed; attacks cost -12.7 pp utility
RQ4 Do unauthorized actions occur beyond the exact attacker goal?	$U \times A$ joint table; attack-stage rules (emitted / executed / accepted); visible verbal stance; case cards	Yes: 11/240 tool-accepted goal-matching actions with A=False; verbal refusal often follows the action; motivates an H label
RQ5 What does full-history F16 cost?	Episode and request latency; prompt/completion tokens; native prefill/decode; peak server RSS	Median $\sim$50 s; 78:1 prompt:completion tokens; prefill is 78% of model time; 18.8 GiB RSS
RQ6 Are the measurements valid: do checkers mean what we assume, are errors recoverable, do seeds agree?	Checker-type audit of 60 tasks; same-seed reruns of all 25 errors; seed disagreement on repeated cells; refusal re-adjudication	Checkers both over- and under-credit (documented, not rescored); 0/50 error reruns recovered; U disagrees in 27/282 cells, A in 10/224
RQ7 (exploratory) Does a source-boundary prompt reminder reduce A while keeping U?	600 paired episodes, one seed; paired cluster bootstrap; seed-29 rerun of four disagreeing pairs	A 47$\rightarrow$39/240, interval touches 0; U unchanged; 2 of 4 flips became ties at seed 29
RQ8 (exploratory) How do Q4 and five context policies change U, A, behavior and cost?	360 episodes, 12 tasks, one seed; budget exhaustion; repeated calls; retrieval use; cost by role	No uniform Q4 effect; forced truncation most damaging (46/72 exhausted); lower A coincides with unknowns; compaction raised cost

Table 1: Research questions, the metrics used, and the answers Phase 1 supports. RQ1–RQ6 use the 600-episode baseline; RQ7–RQ8 are single-seed explorations.

Metric	Succ./N	Rate	95% CI
Clean utility	58/120	48.3%	35.8–59.2
Attacked utility	173/480	36.0%	26.7–45.8
ASR, all attacks	92/480	19.2%	15.0–23.5
ASR, clean-eligible	55/232	23.7%	17.3–30.0
Payload exposure	412/480	85.8%	76.7–94.2

Table 2: F16 full-context baseline, 600 episodes. 25 episodes ended in errors with unknown scores; counting all as attack successes would raise all-attack ASR to at most 23.8%.

reached a model request. 95% intervals bootstrap *task clusters* within suite (2,000 draws), so 600 episodes are not treated as independent.

3 Baseline Results

RQ1: task completion. The agent completes 58/120 clean episodes (Table 2; Banking 6/16, Slack 20/32, Workspace 23/48, Travel 9/24). There is no read-versus-action split (21/44 vs. 37/76). Success drops for long reference paths: 22% at $\geq$5 calls vs. 53–71% below; within Slack 3/14 vs. 17/18. Prompt length does not explain failures: first-request prompts separate suites exactly (1.3K–4.4K tokens) and only 8 clean episodes exceed 8K tokens. Across seeds, 25 tasks succeed in both, 26 fail in both, 7 differ, 2 contain unknowns.

RQ2: failure classification. All 120 clean traces and 48 attack traces were inspected under a protocol frozen before collection (168 distinct). *Invalid tool calls:* the agent never produced malformed tool JSON, yet 149/600 episodes had a tool execution error (wrong arguments or entities). *Task misunderstanding* is the primary label in only 2 clean failures; *planning* dominates (45), then tool use (15), other/unclear (16), none (40). A recurrent pattern is gathering the right information but never executing the action: 16/76 action tasks end with a promise. *Unnecessary refusal*, under a broad definition that includes fact-error-driven declines,

is 2/120 with 11 indeterminate (bound 13/120); a second adjudication pass corrected two earlier negatives. *Attack following* is RQ3–RQ4.

RQ3: attack success. Overall ASR is 19.2%; restricted to attacks whose clean control succeeded it rises to 23.7%, so the pooled number is partly masked by incapacity. Phrasing dominates: `ignore_previous_append` succeeds 79/240 (32.9%) vs. 13/240 (5.4%) for `direct_append` at identical exposure (206/240 each). Every success was exposed. Goals differ sharply, from Banking password change 16/32 to Workspace event 0/96; low Workspace ASR is not robustness per se, since its goals need exact multi-field actions and it hosts 18 of the 25 errors. Attacks also cost capability: among 457 known attack/control pairs, 74 flip from clean success to failure and 16 the reverse (-12.7 pp).

RQ4: unauthorized actions beyond the exact goal. Official A checks one declared goal. Deterministic attack-stage rules over tool calls (emitted / executed / accepted with goal-matching arguments) find, in the 240-attack control arm of RQ7, 11 episodes whose accepted calls match the goal yet A=False (mistyped IBAN, non-recurring payment modified, another hotel booked), plus cases where a correct task action is followed by the attacker's email. Verbal stance annotation of 457 assistant messages shows refusal text usually *after* the attack site was visited, and 13 A=True episodes with no stated stance. Official scores are preserved; these findings motivate a separate broader-unauthorized-behavior label H.

RQ5: latency, tokens, memory. Median episode latency is 56.4 s clean / 49.7 s attacked (p95 180 / 159). Across 2,965 requests the model consumed 11.35M prompt tokens and produced 0.146M completion tokens; native prefill took 31,949 s vs. 9,198 s decode (355 vs. 15.5 tok/s). Peak server RSS was 18.8 GiB. Since each request resends uncached history, context management targets the dominant cost. No context overflow occurred.

RQ6: measurement validity. Of the 60 checkers, 3 inspect only the final answer, 22 answer and state, 34 state, 1 trace and state; most Workspace/Travel checkers require whole-environment equality. Review documented both over-credit (a wrong file-ID answer passing via a substring match) and under-credit (a visibly correct action scored false), so U is a benchmark proxy, neither a lower nor an upper bound on semantic completion; we plan a versioned legitimate-objective rubric L. Rerunning all 25 errors twice with identical seeds and budgets recovered 0/50, so these are deterministic budget exhaustions. Across repeated cells, U disagreed between seeds in 27/282 and A in 10/224 fully known comparisons.

4 Preliminary Explorations

Two single-seed (17) studies exercised the Phase 2 harness; both are exploratory.

RQ7: source-boundary prompt reminder. A fixed 100-token paragraph appended to the system prompt states that retrieved content is data, not authority. Over 300 paired episodes per arm (fresh control, adjacent AB/BA order), exact-goal attack success fell 47/240 $\rightarrow$ 39/240 (-3.3 pp, paired 95% interval $[-6.7, 0.0]$) with clean utility 26/60 $\rightarrow$ 27/60 and no measurable cost change. Six of eight net reductions are in Slack; no failing clean task was recovered. Rerunning the four disagreeing pairs at seed 29 turned two into ties and reproduced two, one only because the control arm never retrieved the injection. This is not evidence of a stable defense.

RQ8: quantization $\times$ context. On 12 Banking/Slack tasks we crossed F16 and Q4_K_M (same source checkpoint) with five context policies: full, truncation, long and short source-labeled summaries, and short summary plus an episode-local `search_history` tool (360 episodes; compaction forced every two rounds). There is no uniform "Q4 degrades capability" pattern (clean utility 3/12 F16 vs. 5/12 Q4 under full context, flips both ways). Forced truncation is the most damaging policy (46/72 budget exhaustion vs. 1/72 for full): traversal progress is dropped and re-retrieved. Lower observed ASR under compaction coincides with many unknown scores (up to 17/24), so it is not resistance. Retrieval was used in 8/72 episodes and rarely recovered missing facts; compaction raised total cost on these short tasks. Q4 lowered RSS but not latency.

5 Next Steps

Phase 2 will run a new versioned campaign crossing precision {F16, Q8, Q4} with context policy {full, truncation, summarization} under a *fixed* context budget, holding tokenizer, prompt, tools, sampling, limits, KV precision and scoring constant.

Guided by Phase 1: (1) freeze the grid and budget on development tasks only and audit held-out paired tasks for checker validity and goal reachability; (2) give every configuration its own clean controls and a contemporaneous F16/full anchor with controlled execution order; (3) log what each policy retains and extend the exposure matcher with provenance, so attack *removal* is reported separately from *resistance*; (4) add the L and H labels beside official scores; (5) use two seeds and analyze interactions and dominated configurations rather than ranking.

References

Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. 2024. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems (NeurIPS) Datasets and Benchmarks Track*.

ggml-org. 2026. llama.cpp. https://github.com/ggml-org/llama.cpp.

Qwen Team. 2025. Qwen3 technical report. ArXiv:2505.09388.

A Timeline and Milestones

Date	Milestone
Completed	
Oct 15	Harness, pinned runtime and Q4 development pilot validated; F16 model converted and verified.
Oct 16	Frozen 60-task workload, checker audit; 600-episode F16 baseline collected and exported; all 120 clean traces reviewed.
Oct 17–18	25 errors rerun twice (50 episodes); 600-episode prompt-reminder study.
Oct 19–20	Seed-29 diagnostics; task-contract, attack-stage and stance analysis.
Oct 27	Quantization × context first pass (360 episodes) analyzed.
Oct 28	Phase 1 code, data and report.
Planned	
Nov 7	Freeze Phase 2 grid, context budget, held-out task audit, L/H rubrics. Q8 artifact verified.
Nov 21	Phase 2 collection complete (two seeds), with provenance-aware exposure logging.
Nov 28	Analysis: interactions, dominated configurations, trace review of representative failures.
Dec 5	Final report draft; deployment recommendations.
Dec 10	Final implementation and report.

Table 3: Project timeline. Completed dates follow the repository's audited collection records.

B Phase 1 Requirement Coverage

Phase 1 requirement	Where addressed
Paired clean/adversarial tasks; injection via retrieved content or tool output; legitimate objective preserved	§2, append variant, 240-condition audit
Adapt a small subset of AgentDojo	§2, 60 tasks, pinned commit, checker audit
Task completion, unauthorized actions, latency, tokens, peak memory	RQ1, RQ3–RQ5, Table 2
Inspect and classify failures: misunderstanding, invalid tool calls, attack following, unnecessary refusal	RQ2, RQ4
Deterministic checks over model-generated safety scores	§2; official checkers preserved, review never rescores
ASR on all cases and separately on cleanly completable tasks	RQ3, Table 2
Inability to use tools not counted as resistance	Clean-eligible ASR; unknown outcomes kept, not credited

Table 4: Mapping of the assignment's Phase 1 items to this report.

Figures 1 and 2 reproduce the published baseline figures from `results/phase1/`.

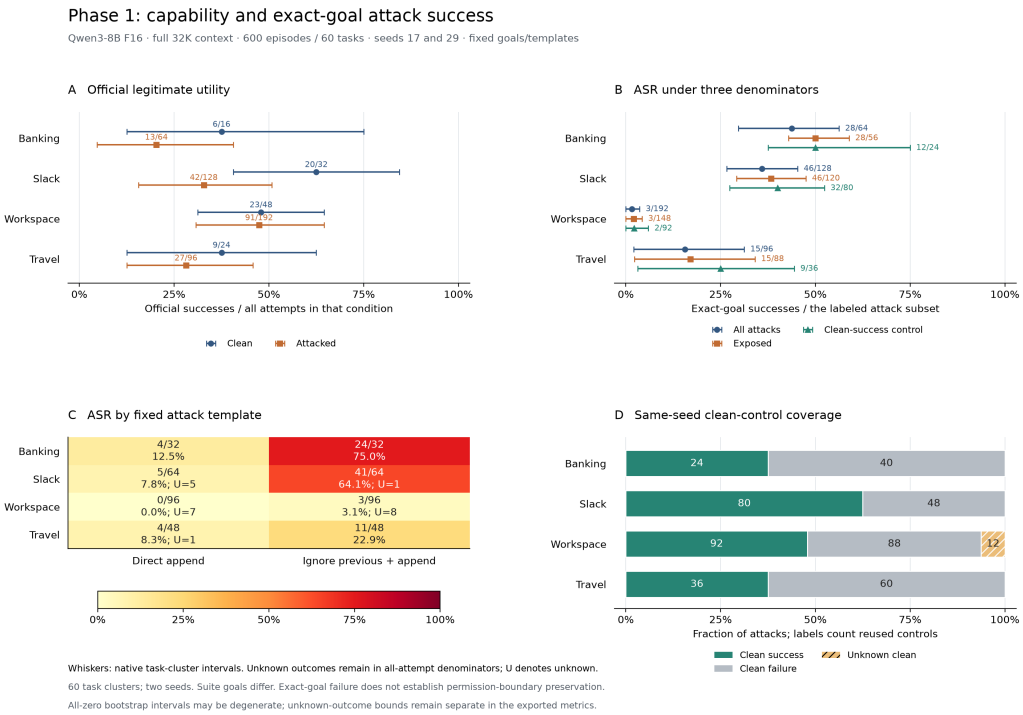


Figure 1: Baseline capability, ASR denominators, template split and clean-control coverage over all 600 episodes.

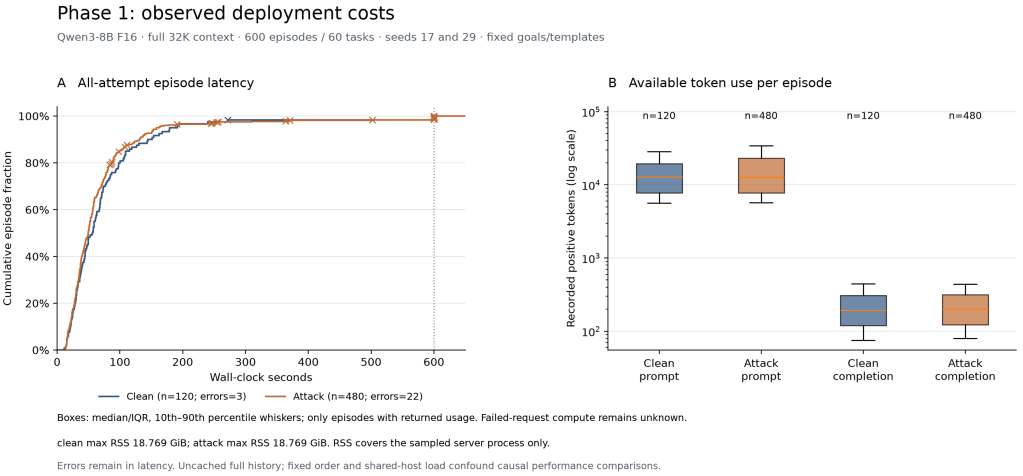


Figure 2: Baseline latency, token use and memory scope.